

AUDITING INFORMATION SYSTEMS

Bachelor of Business Information Technology

BBIT 4.2

Chapters 1 – 12

Lydia Wavinya – HDB212-0278/2022

Adrian Moriasi – HDB212-0238/2022

Samuel Mose – HDB212-0317/2022

Jimmy Musembi – HDB212-0271/2022

Sharleen Gichuki – HDB212-0249/2022

Abby Tuei – HDB212-0343/2022

Henry Joshua – HDB212-0384/2022

Blazious Mwambuwa – HDB212-0342/2022

Moses Obura – HDB212-0383/2022

Lawrence Okoth- HDB212-0385/2022

TABLE OF CONTENTS

Chapter 1 – Introduction to Information Systems Auditing
Chapter 2 – Independence, Ethics, and IS Audit in Corporate Governance
Chapter 3 – Mapping Manual to Automated Controls in a Cash Receipts System
Chapter 4 – IT Risk, IS Audit Planning and the Risk-Based Approach
Chapter 5 – General IT Controls and Application Controls
Chapter 6 – Auditing Systems Development and Change Management
Chapter 7 – Computer-Assisted Audit Techniques (CAATs) – Part I
Chapter 8 – Computer-Assisted Audit Techniques (CAATs) – Part II (Hands-On)
Chapter 9 – Auditing Automated Systems – The NetFlow ISP Case Study
Chapter 10 – CAATs Lab: Creditors and Payroll Dataset Analysis
Chapter 11 – Auditing Non-Monetary Systems – University Student Information System
Chapter 12 – IS Audit of a Payroll Information System

CHAPTER ONE

Introduction to Information Systems Auditing

Why Audit Computerised Systems Differently?

Overview and Learning Objectives

Information Systems (IS) Auditing is a discipline that has grown rapidly alongside the proliferation of computer-based processing in virtually every sector of the economy. Traditional audit approaches, developed for manual accounting environments, are often insufficient — and sometimes entirely inapplicable — in a world where millions of transactions are processed electronically in fractions of a second.

By the end of this chapter, students should be able to:

- Explain why computerised systems require a distinct audit approach from manual systems
- Identify the new categories of risk introduced by IT-dependent processing
- Describe the concept of 'invisible processing' and its implications for auditors
- Distinguish between auditing around the computer, through the computer, and with the computer
- Recognise both the risks and control opportunities created by technology

Class Discussion Prompt

"Why audit computerised systems differently?" — This question sits at the heart of IS auditing. As you work through the five themes below, consider: what would an auditor miss if they simply applied traditional manual audit techniques to a fully computerised environment?

Five Reasons Computerised Systems Demand a Different Audit Approach

1. Volume and Speed of Transactions

Modern information systems can process hundreds of thousands — sometimes millions — of transactions per day. An automated payroll system for a large corporation might generate tens of thousands of payment records in a single pay run. A retail point-of-sale system may record thousands of transactions per hour across hundreds of locations.

Implications for the Auditor:

- Sampling from a very large population introduces the risk that an auditor's sample does not capture anomalies buried deep in the data. A manual review of 50 or 100 records is statistically weak when the population runs to hundreds of thousands.
- The sheer volume of transactions makes 100% examination impractical without automated tools. This has given rise to CAATs — Computer-Assisted Audit Techniques — which allow auditors to examine entire populations electronically.
- Errors and fraudulent transactions can be obscured within large volumes. A fraudster may intentionally make individual transaction values small enough to fall below scrutiny thresholds, relying on volume to generate significant cumulative proceeds.

Example

A bank processes 2.4 million ATM transactions per day. A rounding fraud — where fractions of cents are systematically redirected to a fictitious account — might not be visible in any individual transaction but could aggregate to hundreds of thousands of dollars annually. Only an automated test examining all 2.4 million records would detect the pattern.

2. Invisible Processing – Logic Hidden in Code

In a manual accounting system, every calculation is visible. An accountant adds figures, applies a formula from a policy document, and writes the result. An auditor can trace each step. In a computerised system, processing logic is embedded in software code — typically written in languages such as Java, Python, or C#. This code runs invisibly, often without any human reviewing the intermediate steps. The auditor sees only the input and the output; the transformation between them is concealed within the application.

Implications for the Auditor:

- Program logic risk: A small change in the code — whether accidental or deliberate — can systematically affect thousands or millions of transactions.
- Auditing 'around' the computer: A traditional auditor might test inputs against outputs without interrogating the logic in between — treating the system as a black box. This approach misses entirely the risk that the logic itself is flawed.
- Auditing 'through' the computer: IS auditors examine the code, processing logic, and controls embedded within the system to verify that processing is correct. This may involve reviewing source code, testing applications in a controlled environment, or using embedded audit modules.
- Change management: Unauthorised changes to program code represent a significant risk. Without strong change management controls, a programmer with sufficient access could modify processing logic to commit fraud and then revert the change before a review.

3. Dependence on Systems

Organisations today are profoundly dependent on their information systems. Accounting records, financial statements, operational data, and management information are all stored electronically. In many organisations, no manual fallback process exists for core transactions. This dependence creates several audit-relevant concerns:

- Business continuity risk: A system failure, ransomware attack, or data centre outage can render an organisation unable to process transactions, fulfil orders, or meet financial reporting obligations.
 - Data integrity risk: If the underlying database is corrupted — whether by hardware failure, a software bug, or deliberate manipulation — the financial data presented to stakeholders may be materially misstated.
 - Single points of failure: Heavy reliance on a single system or vendor introduces concentration risk. The failure of one ERP system (e.g., SAP or Oracle) can simultaneously affect financial reporting, procurement, inventory management, and payroll.
-

- **Over-reliance by management:** Where management relies on system-generated reports without understanding the underlying processing logic, errors in automated processes may go undetected for extended periods.

4. New Risk Types – Cybersecurity and Privacy

Computerised environments introduce categories of risk that simply do not exist in manual systems. Two of the most significant are cybersecurity risk and privacy risk.

Cybersecurity Risk

- **External threats:** Hackers, criminal organisations, nation-state actors, and 'hacktivists' may attempt to penetrate organisational systems to steal data, extort organisations (ransomware), disrupt operations, or commit financial fraud.
- **Internal threats:** Employees with system access pose a significant insider threat. A payroll clerk with write access to the employee master file and bank account details could redirect payments to personal accounts.
- **Third-party risk:** Organisations increasingly rely on cloud providers, software vendors, and managed service providers. A breach at a third-party provider can expose the organisation's data even where its own controls are strong.

Privacy Risk

- **Data protection legislation** (such as the GDPR in Europe, POPIA in South Africa, or the Data Protection Act in Kenya) imposes strict requirements on the collection, processing, and storage of personal data. Non-compliance can result in significant regulatory penalties and reputational harm.
- **Payroll systems, HR databases, customer records, and transaction files** often contain sensitive personal information. The IS auditor must assess whether data is collected lawfully, retained only as long as necessary, adequately secured, and accessible only to authorised users.

Regulatory Context – Kenya

The Data Protection Act (2019) establishes obligations for data controllers and processors, including requirements for lawful processing, data subject rights, and mandatory breach notification. IS auditors in this jurisdiction must assess compliance with these requirements as part of their review scope.

5. The Opportunity for Stronger Automated Controls

While computerised systems introduce new risks, they also create significant opportunities for controls that are far more effective and consistent than their manual equivalents. Technology is not only a source of audit risk — it is also a powerful mechanism for risk mitigation.

Control Type	Manual Equivalent	Automated Advantage
Duplicate payment prevention	Manual review of invoices	System rejects invoices with duplicate InvoiceNo automatically
Segregation of duties	Physical separation of staff	Role-based access controls prevent one user from both creating and approving records
Authorisation controls	Manual signature on payment vouchers	Workflow system requires digital approval from designated authority before processing
Completeness checks	Batch control totals manually compared	System compares batch hash totals automatically and rejects mismatches
Audit trail	Manual ledger entries with date and clerk ID	Automated timestamp, user ID, and before/after field values logged for every transaction change
Reasonableness checks	Supervisor reviews unusual amounts	System applies validation rules and rejects values outside parameters

Comparing the Auditor's Approach: Manual vs Computerised Environments

Dimension	Manual System	Computerised System
Transactions	Low volume, traceable individually	High volume; requires automated tools to analyse
Processing	Visible; each step documented	Invisible; logic embedded in code
Errors	Random and inconsistent	Systematic — one coding error propagates to all records
Evidence	Paper documents, physical signatures	Electronic records, digital logs, audit trails
Fraud risk	Requires physical forgery	May be perpetrated through code changes, access exploitation
Audit trail	Visible, often chronological	Must be specifically designed; may be alterable
Control testing	Inspect documents, observe processes	Test application controls, review access logs, use CAATs

Summary and Discussion Themes

- **Volume and speed:** Traditional sampling techniques are insufficient; automated analysis of full populations is required
 - **Invisible processing:** Auditors must go beyond inputs and outputs to evaluate the logic that connects them
 - **System dependence:** The reliability and availability of systems must be assessed as part of the overall audit
 - **New risk types:** Cybersecurity and privacy risks require dedicated assessment frameworks and specialist knowledge
-

- **Automated control opportunities:** Technology creates the possibility of controls that are more reliable, consistent, and comprehensive than manual alternatives

Key Insight

IS auditing is not simply 'IT auditing' in the sense of auditing technology. It is the audit of business processes and financial reporting that are conducted through, controlled by, and dependent upon information technology. Every auditor in a modern environment must develop a baseline understanding of IS audit principles.

Suggested Further Reading

- ISACA: COBIT 2019 Framework — Governance and Management Objectives
- IIA: Global Technology Audit Guide (GTAG) – Auditing IT General Controls
- PCAOB AS 2201: An Audit of Internal Control over Financial Reporting
- Greenstein & Vasarhelyi: Electronic Commerce — Security, Risk Management and Control
- Kenya ICT Authority: Data Protection Regulations (2021) under the Data Protection Act, 2019

CHAPTER TWO

Independence, Ethics, and IS Audit in Corporate Governance

Case Analysis: Independence Threats in IS Audit

Part A: Case Analysis – Independence Threats in IS Audit

Background Summary

The scenario presents a classic independence conflict: an internal IS auditor is assigned to audit a payroll system they helped implement and continue to informally advise on. This cuts to the heart of one of auditing's most fundamental principles — that auditors must be, and appear to be, free from conditions that threaten their objectivity.

1. Threats to Independence

Several distinct threat categories are at play here, drawing from both ISACA's Code of Professional Ethics and the broader framework used in standards like ISSAI and IIA's International Standards.

Self-Review Threat — This is the most significant threat. When an auditor evaluates their own prior work, they are psychologically and professionally predisposed to validate decisions they made during implementation. Acknowledging flaws in the system would amount to criticizing themselves, making truly objective assessment nearly impossible.

Familiarity Threat — The ongoing informal advisory relationship with HR deepens this problem. Repeated informal interactions build personal relationships and loyalty that can cloud professional judgment.

Advocacy Threat — Having championed or contributed to design decisions during implementation, the auditor may find themselves defending those choices during the audit rather than scrutinizing them impartially.

Self-Interest Threat — If the auditor's performance was evaluated partly on the success of the implementation, a critical audit finding could reflect negatively on their own past work record — creating a personal stake in a favorable outcome.

Structural/Organizational Threat — As an internal auditor, they may already face reporting line pressures. Layering implementation involvement on top of institutional proximity compounds the independence problem significantly.

2. How These Threats Affect Audit Credibility

The impact operates on two levels — actual and perceived — and both matter equally in auditing.

Actual impairment may result in the auditor unconsciously overlooking control gaps, rationalizing weaknesses they designed into the system, or failing to probe areas where they know their own work was rushed or incomplete.

Perceived impairment is equally damaging. Even if the auditor somehow produces a perfectly objective report, any informed stakeholder who discovers the prior involvement will reasonably question the report's validity. In audit, the appearance of independence is not secondary to actual independence — it is equally required.

Practically, this could lead to: audit findings being dismissed or disputed by auditees; external auditors declining to place reliance on the internal audit work; regulatory scrutiny if the payroll system is subject to compliance requirements; and reputational damage to the entire internal audit function.

3. Applicable Safeguards

Safeguards should be proportional to the severity of the threat. In this case, given that both past implementation and ongoing advisory involvement are present, mild safeguards are insufficient.

Primary Safeguard — Reassignment: The most direct remedy is removing the auditor from the engagement entirely. ISACA's standards are clear that where independence cannot be maintained, the individual should not participate.

Enhanced Review: If reassignment is partially unavoidable, any contribution by this auditor must be subject to rigorous independent review by a senior auditor or the Chief Audit Executive.

Termination of Advisory Role: The informal advisory relationship with HR must be formally ended before any audit activity begins.

Disclosure and Documentation: If any involvement by this auditor is retained, it must be fully disclosed in the audit report. The working papers should document the independence consideration and the decision made.

External Quality Assurance: For high-risk systems like payroll, commissioning an external reviewer to assess the audit's methodology and conclusions adds an independent layer of credibility.

4. Internal vs. External Audit — Does the Answer Change?

The core principle — independence must be maintained — does not change. However, the standards applied and the consequences differ meaningfully.

For an external auditor, having previously implemented the system being audited would almost certainly constitute a disqualifying conflict of interest under standards like ISA 200 and the IESBA Code of Ethics. There is no safeguard that adequately compensates — the auditor firm would need to withdraw from the engagement entirely. The governing standards are stricter, violations carry legal and regulatory consequences, and the disclosure obligation extends to the public audit report.

For an internal auditor, the IIA's standards allow for more nuanced mitigation through safeguards, and the independence requirement is framed around organizational positioning and objectivity rather than full legal independence. That said, the bar remains very high — particularly where an ongoing advisory role exists. The matter would typically be escalated to the Chief Audit Executive and, where necessary, the Audit Committee.

Part B: The Role of IS Audit in Strengthening Corporate Governance

Introduction

Corporate governance has long been concerned with accountability, transparency, and the protection of stakeholder interests. At its core, it describes the system by which organisations are directed and controlled — encompassing the responsibilities of boards of directors, audit committees, management, and external assurance providers. Today, an organisation that governs its financial affairs well but neglects its information systems is not governing well at all. IS audit

has emerged as an indispensable instrument of corporate governance — assuring the integrity of technology-dependent operations, evaluating IT governance structures, and equipping boards with the insight needed to navigate an increasingly complex risk landscape.

Corporate Governance and the Role of the Board and Audit Committee

Corporate governance frameworks — including the OECD Principles of Corporate Governance, the King IV Report, and national codes across various jurisdictions — consistently assign the board of directors ultimate accountability for organisational oversight. Within this structure, the audit committee plays a particularly critical role: it oversees financial reporting integrity, internal controls, risk management, and the work of both internal and external auditors.

Boards cannot make sound decisions on the basis of information they cannot trust, and in a world where earnings reports, risk dashboards, and compliance disclosures are all products of complex IT systems, whether those systems are functioning as intended is a governance question, not merely a technical one.

How IT Reliance Changed Governance Expectations

The widespread adoption of Enterprise Resource Planning systems, cloud-based platforms, and data analytics tools means that financial statements are now largely system-generated artefacts. Transactions are initiated, processed, approved, and recorded by automated workflows with minimal human intervention. This dependency has created new categories of risk that traditional governance mechanisms were not designed to address: data breaches, system failures, poor IT governance, and cyber threats now rank among the top enterprise risks globally.

Specific Ways IS Audit Supports Corporate Governance

Assurance on System-Generated Information: IS auditors examine application controls — input validation, processing accuracy, output completeness — as well as the general IT controls that underpin them (change management, logical access, IT operations). Without this assurance, the board is, in effect, signing off on numbers whose provenance it cannot verify.

IT Governance Evaluation: Drawing on frameworks such as COBIT, IS auditors assess whether IT investments are aligned with business strategy, whether IT risks are being appropriately managed, and whether IT performance is being reported effectively to leadership.

Cyber and Data Protection Risk Assessment: IS auditors evaluate the design and effectiveness of cybersecurity controls — including network security, vulnerability management, incident response readiness, and data protection practices. These assessments provide the board with an objective picture of the organisation's cyber risk posture.

Contribution to Risk-Based Audit Planning: By mapping the organisation's technology landscape and identifying IT-related risks, IS auditors help ensure that the overall audit plan reflects the realities of a technology-dependent organisation.

Professional Standards and Ethics

The credibility of IS audit as a governance instrument rests substantially on the professional standards and ethical principles that govern its practice. ISACA's IT Audit and Assurance Framework (ITAF) establishes standards covering independence, competence, due professional care, confidentiality, and the quality of audit evidence. ISACA's Code of Professional Ethics further requires IS auditors to support the implementation of appropriate IT governance, inform appropriate parties of audit results, and maintain the privacy and confidentiality of information obtained during engagements.

Future Challenges: AI, Cloud, and Big Data

Artificial Intelligence is increasingly embedded in organisational decision-making — from credit scoring to fraud detection to HR recruitment. Auditing AI systems requires IS auditors to grapple with questions of algorithmic transparency, bias, explainability, and accountability that existing frameworks are only beginning to address.

Cloud Computing has moved critical data and processing outside organisational boundaries. IS auditors must evaluate not just the organisation's own controls but also the governance arrangements surrounding cloud service providers, including contract terms, shared responsibility models, and the use of third-party assurance reports such as SOC 2.

Big Data and Advanced Analytics are transforming how organisations use information — and how IS auditors work. IS auditors are increasingly equipped with data analytics tools that allow them to examine entire populations of transactions rather than samples, potentially strengthening audit quality considerably.

Conclusion

The role of IS audit in corporate governance is neither peripheral nor merely technical — it is central and strategic. By validating the reliability of system-generated information, evaluating IT governance structures, assessing cyber and data risks, and contributing to risk-based audit planning, IS audit equips boards and audit committees to fulfil their oversight responsibilities with genuine confidence. Grounded in professional standards and ethical conduct, IS audit stands as one of the most important pillars of modern corporate governance.

CHAPTER THREE

Mapping Manual to Automated Controls

Exercise: Cash Receipts System

The Scenario

An organization has moved from a manual cash receipts process to an online receipting system integrated with the accounting system. For each manual control, the exercise identifies the automated equivalent, any new IT-specific controls needed, and how an auditor would test them.

The Manual Process

A cashier receives cash and issues a pre-numbered receipt. A clerk records the receipt in a cash book. A supervisor reconciles the cash book to the bank deposit slip and the pre-numbered receipts. An accountant then posts totals to the general ledger. These four roles are deliberately separate — the manual segregation of duties.

Mapping: Manual Controls to Automated Equivalents

Manual Control 1: Pre-Numbered Receipts

Purpose: Ensure every transaction is captured and that none can be hidden by destroying a receipt — because a missing number would be noticed.

Automated Equivalent: The online receipting system automatically generates a unique, sequential receipt number for every transaction at the point of processing. This number is system-generated and cannot be manually edited, skipped, or reused. The system enforces this through a built-in sequence generator tied to the database.

What this means: A cashier cannot issue a receipt with a self-chosen number, cannot skip a number to hide a transaction, and cannot reuse a cancelled receipt number without leaving a traceable record in the system log.

Manual Control 2: Clerk Records Receipts in a Cash Book

Automated Equivalent: When a receipt is processed in the online system, it is automatically posted in real time to both a cash receipts journal and the general ledger (GL) simultaneously.

There is no separate manual recording step — the system does it instantly and consistently for every transaction.

What this means: There is no delay between receiving cash and it appearing in the accounting records. The system eliminates the risk of a clerk forgetting to record a receipt, recording it in the wrong amount, or deliberately omitting it from the cash book.

Manual Control 3: Independent Reconciliation

Automated Equivalent: The system has an automated bank interface and reconciliation tool that pulls electronic bank statement data directly from the bank and matches it against receipts posted in the system. Any unmatched items are automatically flagged as exceptions for review.

What this means: Instead of a supervisor manually comparing paper documents, the reconciliation runs automatically and produces an exception report. This is faster, more comprehensive, and less susceptible to human fatigue or collusion.

Manual Control 4: Segregation of Duties

Automated Equivalent: The system enforces role-based access control (RBAC) that prevents any single user from performing incompatible functions. The cashier's login only allows receipt issuance. A different role is required to perform end-of-day approval. Only a designated finance officer role can post adjusting entries or reversals.

What this means: Even if a cashier wanted to both issue a receipt and then reverse or hide it, the system would not allow it — the reversal function is locked behind a different role and login. Segregation is enforced by configuration, not just by policy or physical separation.

New IT-Specific Controls Required

When you move to an automated system, new risks arise that did not exist in the manual process. These require controls that have no direct manual equivalent.

New Control 1 — User Access Control: A formal process for creating, modifying, and removing user accounts is required, including strong password policies, multi-factor authentication for sensitive roles, and immediate revocation of access when staff leave or change roles.

New Control 2 — Daily Backup of Transaction Data: Scheduled, automated daily backups of all receipt transaction data are required, stored securely offsite or in the cloud, tested periodically for restorability, and encrypted to prevent unauthorized access.

New Control 3 — System Logs: The receipting system must maintain detailed, tamper-proof logs recording: which user processed each receipt, the exact timestamp, the amount and receipt number, and any subsequent modifications or reversals. These logs should be stored separately from the main application.

New Control 4 — Input Validation and Edit Checks: The system should reject or flag: receipts with a zero or negative amount, receipt dates outside the current business day, amounts above a pre-set single-transaction limit, and duplicate submissions of the same receipt reference within a short time window.

New Control 5 — End-of-Day Closure and Batch Approval: A formal end-of-day closure process where a supervisor with a different system role reviews the day's total receipts, compares the system total to the physical cash count, and formally approves the daily batch before it is locked in the accounting system.

How an Auditor Would Test These Automated Controls

Testing the sequential receipt number control: The auditor uses a CAAT to extract the full population of receipt numbers for a given period and runs a sequence check — identifying any gaps (missing numbers) or duplicates. The auditor also reviews system configuration to confirm the receipt number field is system-generated and locked from manual editing.

Testing the automated GL posting control: The auditor selects a sample of receipts and traces each to the corresponding GL entry, confirming that amounts, dates, and references match exactly. Any receipts with no corresponding GL entry indicate a significant control deficiency.

Testing the automated bank reconciliation: The auditor reviews the reconciliation exception report, notes the number and value of unmatched items, and selects a sample of flagged exceptions to confirm each was properly investigated and resolved. Unmatched items remaining outstanding for unusually long periods are closely investigated.

Testing the role-based access control: The auditor obtains a system-generated user access listing and confirms that each user's role matches their job description. The auditor also checks whether any users have multiple conflicting roles, and whether the access of any terminated staff members was removed in a timely manner.

Testing the system logs: The auditor reviews the system log for reversals of posted receipts, entries made outside normal working hours, entries by administrator or privileged accounts, and any gaps in the log sequence that might indicate tampering.

Testing the backup control: The auditor inspects the backup schedule, confirms it runs daily, reviews backup logs for successful completion, checks whether restoration tests have been performed and documented, and confirms backups are stored securely and encrypted.

CHAPTER FOUR

IT Risk, IS Audit Planning and the Risk-Based Approach

1. Identifying Key Systems and Processes

(a) ERP System for Finance and Procurement

This system handles financial transactions and procurement activities. Key processes include revenue recording, procurement and purchasing, supplier payments, and financial reporting. The ERP system integrates finance and procurement functions into one centralized system. Because it processes high-value transactions, it is considered a critical system. If the ERP system fails or contains weak controls, the organization may experience duplicate payments or inaccurate financial reports.

(b) HR/Payroll System

This system manages employee records and payroll processing. Key processes include employee registration, salary processing, allowance and deduction calculations, and payroll reporting. The payroll system is sensitive because it contains confidential employee information and handles salary payments. If unauthorized users gain access, they may create ghost employees and process fake salaries.

(c) Online Customer Portal

This platform allows customers to place orders and make payments online. Key processes include customer registration, online ordering, payment processing, and billing and invoicing. Since the portal is internet-facing, it is exposed to cyber threats such as hacking and data breaches.

(d) IT Infrastructure (Cloud and On-Premise)

This includes servers, databases, networks, cloud services, and backup systems. Infrastructure supports all organizational systems. Weak infrastructure controls may affect all departments simultaneously. A server failure without proper backups may lead to loss of financial and customer data.

2. Main IT Risks for Each Area

(a) ERP System Risks

Unauthorized Access: Unauthorized users may access financial records and manipulate transactions. An employee may alter supplier payment details and redirect funds to personal accounts.

Duplicate Payments: Weak processing controls may allow invoices to be paid more than once. The same supplier invoice may be processed twice due to missing duplicate checks.

Weak Change Management: Unauthorized system changes may introduce errors or security vulnerabilities. A developer may modify tax calculation rules without approval, leading to incorrect financial reporting.

(b) Payroll System Risks

Ghost Workers: Fake employees may be added into the payroll system. A payroll officer may create non-existent employees and collect their salaries fraudulently.

Unauthorized Salary Adjustments: Employees may alter salary details without proper authorization. An HR staff member may increase their own salary in the system.

Data Confidentiality Risks: Payroll data may be exposed to unauthorized persons, including external parties.

(c) Online Customer Portal Risks

Data Breaches: Hackers may steal customer data and payment details through phishing attacks and other means.

Incorrect Pricing: System errors may generate incorrect product prices, causing revenue losses.

Downtime and Service Interruptions: A denial-of-service attack may prevent customers from accessing the website during peak business periods.

(d) Infrastructure Risks

Loss of Data: Data may be lost due to hardware failure or cyberattacks. Ransomware may encrypt company databases and block access.

Weak Backup Procedures: Backups may fail or may not be tested regularly. The company may discover corrupted backup files after a server crash.

Network Security Risks: Poor network security may allow unauthorized access. Hackers may exploit outdated firewall configurations.

3. Risk Prioritization

System/Area	Risk	Priority	Explanation
Online Customer Portal	Data breaches	High	Internet-facing systems are highly exposed to cyberattacks; customer trust may be damaged
ERP Finance System	Unauthorized financial transactions	High	Financial fraud may lead to major losses and inaccurate reporting
Payroll System	Ghost workers	High	Causes direct financial loss and payroll fraud
IT Infrastructure	Weak backup and disaster recovery	High	System failure may stop operations completely
ERP System	Duplicate payments	Medium	Causes financial losses but may be detected later through reconciliations
Customer Portal	Incorrect pricing	Medium	Affects revenue and customer confidence
Infrastructure	Minor network outages	Low	Short interruptions may have limited impact if resolved quickly

4. Audit Scope and Objectives

Audit Scope

The audit will review: General IT controls; Application controls; ERP finance and procurement system; HR/payroll system; Online customer portal; and Backup and disaster recovery controls. Covering the current financial year at the head office, cloud-hosted infrastructure, and main data center.

Audit Objectives

- Assess whether access controls prevent unauthorized access to systems (e.g., verify whether former employees still have active accounts)
- Evaluate whether payroll transactions are complete, accurate, and authorized (e.g., verify whether salary changes require management approval)
- Determine whether online sales transactions are processed correctly (e.g., confirm whether customer payments are recorded accurately in the ERP system)
- Assess the effectiveness of backup and disaster recovery procedures (e.g., check whether backup restoration tests are performed regularly)

5. Proposed Audit Tests

User Access Review: Review user accounts and access rights to check whether users have appropriate permissions according to their job responsibilities (e.g., ensure payroll officers cannot approve their own salary changes).

Password Policy Review: Examine system password configurations. Verify whether passwords expire regularly, multi-factor authentication is enabled, and accounts lock after repeated failed logins.

CAATs on Sales Data: Use Computer-Assisted Audit Techniques to identify unusual transactions including duplicate sales invoices, negative sales values, and excessive discounts.

Payroll Data Analysis: Analyze payroll records for anomalies: employees sharing the same bank account; employees without valid identification numbers; and duplicate employee records.

Review Incident Logs: Inspect logs relating to the customer portal breach to determine what happened, who accessed the system, and whether incidents were handled properly.

Backup and Disaster Recovery Testing: Review backup reports and disaster recovery test results. Restore sample backup files to confirm successful recovery.

6. Short IS Audit Plan

Background: The organization operates an ERP finance system, payroll system, and online customer portal. Recent issues include a customer portal data breach and weak access management findings from prior audits. Online transactions are also increasing rapidly.

Audit Scope: ERP finance and procurement system; HR/payroll system; Online customer portal; General IT controls; Backup and disaster recovery procedures.

Key Risks: Unauthorized access; Data breaches; Payroll fraud; Duplicate payments; Weak backup procedures; System downtime.

Main Audit Procedures: User access review; Password policy testing; CAATs on payroll and sales data; Incident log review; Backup and recovery testing; Review of change management controls.

Proposed Timeline

- Planning and risk assessment – 1 week
- Fieldwork and testing – 2 weeks
- Data analysis and evaluation – 1 week
- Reporting and presentation – 1 week

CHAPTER FIVE

General IT Controls and Application Controls

Observation and Classification Exercise – ERP Order-to-Cash Module

5.1 Observing the Environment

We observed an ERP system focused on the Order-to-Cash module. The login screen required a username and password. After successful login, the main menus displayed included Sales Orders, Invoicing, Customer Master, Payments, and Reports.

User roles observed were Sales Clerk, Billing Clerk, Credit Officer, Cashier, and Manager. Each role had different menu access. For example, a Sales Clerk could see the Sales Orders menu but could not see the Invoicing or Payments menus. The system also showed workflow indicators such as Pending Approval, Approved, Invoiced, and Paid, allowing users to track the status of each transaction.

5.2 General IT Controls Identified

Control 1 – User Authentication (General IT Control): Every user is required to log in with a unique username and password before accessing any system functions. This control prevents unauthorized access to the system.

Control 2 – Role-Based Access Control (General IT Control): Users can only access functions related to their assigned job role. For example, a Sales Clerk cannot create invoices. This control enforces segregation of duties.

Control 3 – Audit Trail (General IT Control): The system automatically logs all user activities including logins, data entry, modifications, approvals, and deletions. Each log entry captures the user ID, timestamp, and action performed.

Control 4 – Password Policy (General IT Control): The system enforces password complexity rules such as minimum length and required character types. Passwords expire after ninety days, and users cannot reuse previous passwords.

Control 5 – Backup and Recovery (General IT Control): The system performs regular automated backups stored securely off-site. This control protects against permanent data loss.

Control 6 – Change Management (General IT Control): Any modifications to the system require proper authorization, testing in a non-production environment, and documentation before implementation.

5.3 Application Controls Identified

Control 1 – Mandatory Fields (Application Control): When creating a sales order, fields such as Customer Name, Product Code, Quantity, and Unit Price were required. The system would not save the order if any mandatory field was left blank.

Control 2 – Drop-Down Menus (Application Control): Instead of typing product codes freehand, users had to select from predefined drop-down lists referencing master data tables. This prevents invalid or misspelled codes.

Control 3 – Automatic Tax Calculation (Application Control): The system automatically calculated taxes based on customer location and product type, eliminating manual calculation errors and ensuring consistent tax application.

Control 4 – Credit Limit Check (Application Control): Before confirming an order, the system checked whether the customer's outstanding balance plus the new order amount exceeded their approved credit limit. If exceeded, the order was blocked or required approval.

Control 5 – Three-Way Matching (Application Control): Before a supplier invoice could be paid, the system matched the invoice against the purchase order and goods receipt note. This prevents duplicate or fraudulent payments.

Control 6 – Approval Workflow (Application Control): Sales orders above a certain threshold required manager approval before proceeding to invoicing. The order status changed to Pending Approval until a manager approved it.

Control 7 – Report Access Restrictions (Application Control): Sensitive reports such as aging receivables were only accessible to authorized roles. A Sales Clerk could not view these reports. This control protects confidential customer data.

Control 8 – Master Data Approval Workflow (Application Control): When a user created a new customer, the record was saved as Pending Approval. A manager had to approve it before the customer could be used in transactions. This prevents fake customers from being created.

5.4 Classifying Each Control

Control	Type	Classification	Without This Control...
User Authentication	General IT	Preventive	Anyone could access the system and create fake invoices
Role-Based Access	General IT	Preventive	A single user could create fake customers, orders, invoices, and payments
Audit Trail	General IT	Detective	No way to trace who changed a price or deleted an invoice
Password Policy	General IT	Preventive	Users could choose weak passwords easily guessed by attackers
Backup and Recovery	General IT	Corrective	All transaction history and master data could be permanently lost
Change Management	General IT	Preventive	Developers could introduce errors or backdoors without testing
Mandatory Fields	Application	Preventive	Incomplete orders could be saved, causing billing errors
Drop-Down Menus	Application	Preventive	Invalid product codes would cause processing errors
Automatic Tax Calculation	Application	Preventive	Manual tax errors would cause incorrect invoice amounts
Credit Limit Check	Application	Preventive	Organization could sell to customers unable to pay, resulting in bad debt
Three-Way Matching	Application	Preventive	Organization could pay for goods not received or pay same invoice twice
Approval Workflow	Application	Preventive	A Sales Clerk could enter a fraudulent high-value order without oversight

Control	Type	Classification	Without This Control...
Report Access Restrictions	Application	Preventive	Any user could view sensitive customer financial data
Master Data Approval Workflow	Application	Preventive	A user could create a fake customer and issue invoices without detection

5.5 Report Back – Key Points

- User Authentication (General IT, Preventive): Requires every user to log in with a unique username and password. Without this, anyone could access the system and create fake invoices.
- Mandatory Fields (Application, Preventive): The system requires Customer Name and Product Code before saving an order. Without this, incomplete orders would cause billing errors.
- Audit Trail (General IT, Detective): The system logs every transaction including who did it and when. Without this, there would be no way to trace who changed a price or deleted an invoice.

5.6 Conclusion

General IT Controls and Application Controls work together to ensure system reliability and data integrity. General controls provide the foundation for the entire IT environment, while application controls protect individual transactions. A well-controlled system includes both types, with an emphasis on preventive controls supported by detective and corrective controls.

CHAPTER SIX

Auditing Systems Development and Change Management

Case Study: Payroll System Implementation Gone Wrong

Background

A public institution rolled out a new payroll system and almost immediately encountered serious problems. Employees were not being paid, some were being overpaid, ghost workers appeared out of nowhere, user roles had no separation of duties, the data migration was rushed and messy, and User Acceptance Testing (UAT) was performed by a small group that barely examined the full scope of system requirements. This is a textbook case of what happens when the Systems Development Life Cycle (SDLC) is treated as a formality rather than a real governance process.

Question 1: Which SDLC Phases Were Weak?

Requirements Phase

Ghost workers appeared and role configurations allowed a single person to both create employees and approve payments — demonstrating that the requirements phase never properly captured control requirements. The failure to involve the right stakeholders (finance, HR, internal audit) at this stage is what set the project up for failure from the start.

Design Phase

The poor role configuration at go-live is a design failure. The system was built allowing individuals to have both 'create employee' and 'process payment' rights — a segregation of duties violation baked directly into the architecture. Good design would have had separate roles with workflow approvals at each step.

Testing Phase

UAT was done by a small group focused mainly on basic functionality, not exception scenarios. A payroll system needs to be tested for: what happens when a duplicate employee record is created; what happens when an employee is added without HR approval; can a user approve their own payment; and what error messages appear for invalid entries. None of these were examined.

Implementation (Deployment) Phase

The rushed data migration resulted in incomplete records and duplications — demonstrating that no proper data reconciliation occurred between the old system and the new one. A responsible migration process involves mapping old fields to new fields, running parallel systems for a period, and reconciling totals before switching over completely.

Question 2: Specific Control Weaknesses

Segregation of Duties (SoD) Failure

The system was configured so certain users could both create employee records and process payments without needing a second person to approve. In payroll systems, at least three separate roles are needed: HR (creates and maintains employee records), Payroll (processes pay runs based on approved records), and Finance/Management (approves and releases payments). When one person can do all three, it creates a perfect fraud environment. Ghost workers appearing in the system is almost certainly a result of this weakness.

Lack of Validation Controls

A properly designed payroll system should have validations at every critical input point: bank account numbers validated against approved lists; new employee entries requiring a corresponding HR approval workflow; and salary figures outside an approved range flagged for review. From what occurred, these validations either were not implemented or were not enforced.

Inadequate Data Migration Controls

A good migration process involves: a data mapping document showing how old fields translate to new fields; a data cleansing exercise before migration; reconciliation totals compared between old and new systems; and sign-off from HR and Finance confirming the migrated data is accurate. None of this seems to have happened.

Section 6.6 – Mid-Course Quiz Outline (Weeks 1–5)

Conceptual Questions

What is IS Auditing? IS auditing is the process of evaluating an organization's information systems, related controls, and IT governance to determine whether they are effective, reliable, and secure. Unlike a financial audit that focuses on financial statements, an IS audit digs into the IT environment that produces and manages the data those financial statements are based on.

What is Materiality in an IS Audit? Materiality refers to the significance of a finding in terms of its potential impact on the organization. A finding is material if its impact could be significant to business operations, financial reporting, or compliance.

What is Audit Risk? Audit risk is the risk that an auditor issues an incorrect conclusion. It comprises: Inherent risk (the risk that exists before any controls are applied); Control risk (the risk that existing controls fail to prevent or detect errors); and Detection risk (the risk that the auditor's own procedures fail to catch a problem).

General Controls vs. Application Controls

General controls are broad IT controls that apply across the entire IT environment — things like access management, change management, backup and recovery, and IT governance. They create the environment within which application controls operate.

Application controls are specific to individual systems or processes — things like input validation, processing controls (ensuring every transaction is processed once and only once), and output controls (confirming reports are complete and accurate). If general controls are weak, application controls cannot be relied upon, because the environment they operate in is unreliable.

COSO Components in an IS Context

COSO Component	IS Application
Control Environment	IT governance structure, management's attitude to security, ethics policies for IT staff
Risk Assessment	IT risk assessments, threat identification (cyber threats, system failures, data breaches)
Control Activities	Access controls, change management, system backups, data validation

COSO Component	IS Application
Information & Communication	Audit logs, exception reports, IT security alerts, management dashboards
Monitoring Activities	Continuous monitoring tools, periodic IS audits, vulnerability scans, performance reviews

Choosing Appropriate Audit Procedures for a Risk

Risk	Appropriate Audit Procedure
Unauthorized changes to production	Sample changes from the change log and trace each through the full approval chain
Ghost workers in payroll	Reconcile the employee list in the payroll system against the HR master register
SoD violations in user access	Review user role assignments and identify users with conflicting roles; use role matrix analysis
Data migration errors	Compare record counts and key totals between old and new systems; sample individual records for accuracy
Inadequate UAT	Review test plans and test case results; check whether negative/exception scenarios were included
Emergency change bypass	Review the emergency change log; confirm retrospective approvals and documentation were completed

CHAPTER SEVEN

Computer-Assisted Audit Techniques (CAATs) – Part I

Concepts, Tools, and Techniques

1. Introduction to CAATs

Computer-Assisted Audit Techniques (CAATs) are tools and methods that use computers to help auditors examine, test, and analyze information systems and electronic data. CAATs allow auditors to analyze large datasets, test automated controls, detect fraud and anomalies, recalculate transactions, and improve audit efficiency.

Why CAATs Are Important

Modern organizations use computerized systems that process thousands of transactions automatically. Manual auditing alone may miss fraud patterns, miss duplicate transactions, be slow and inefficient, and fail to test entire datasets. CAATs enable full population testing, faster audits, better fraud detection, and improved accuracy.

2. Test Data / Test Decks

Test data refers to artificial transactions created by auditors to test whether application controls work correctly. The auditor inputs both valid and invalid transactions. The system should accept valid entries and reject invalid entries.

Example: In a payroll system, the auditor would input a negative salary amount, an invalid employee ID, and a duplicate employee number. The system should reject or flag these errors.

Strengths: Tests input controls directly; auditor knows expected outcomes; useful for validation testing.

Limitations: Tests only selected cases; requires test environment; must be updated after system changes.

3. Integrated Test Facility (ITF)

ITF involves creating fictitious records inside the live production system to continuously test controls during normal processing. Examples include a dummy employee or fake customer account.

Example: A fictitious employee is added to the payroll system to test payroll calculations, approval processes, and payment controls.

Strengths: Continuous testing; uses live processing environment; tests operational procedures.

Limitations: Risk of contaminating real data; requires careful monitoring; staff may identify the fictitious records.

Key Difference from Test Data: Test data is processed in a separate test environment, while ITF operates inside the live production system.

4. Parallel Simulation

Parallel simulation involves independently reprocessing client data using the auditor's software and comparing results with the organization's system outputs. An auditor might independently recalculate payroll, loan interest, or taxes and compare results with system calculations.

Strengths: Uses real data; effective for complex calculations; detects processing errors.

Limitations: Requires technical expertise; time-consuming setup; simulation must be accurate.

5. Tracing Techniques

Tracing follows a transaction through the system step by step from input to final output. Tracing is used to understand transaction flow, identify processing errors, and detect fraud. It helps auditors identify where errors or unauthorized activities occur.

6. Program Mapping

Program mapping creates visual diagrams showing program logic and data flow. It is used to understand system processing, identify weak controls, and review complex programs. It helps auditors understand complex system logic visually.

7. Code Comparison Techniques

Code comparison compares different versions of system programs to identify changes. Uses include detecting unauthorized modifications, reviewing system updates, and supporting change management audits. It helps verify that only approved changes were made to the system.

8. Strengths and Limitations of CAATs

Strengths: Faster auditing; full population testing; better fraud detection; improved accuracy; effective testing of automated systems.

Limitations: Require technical skills; expensive software/tools; depend on system access; complex implementation.

9. Audit Software Packages and Data Analysis Tools

Common audit tools include ACL, IDEA, SQL, and Excel-based CAATs. These tools help auditors extract data, analyze transactions, detect anomalies, and generate reports.

10. Data Extraction Concepts

File Formats: Common formats include CSV, Excel, TXT, and database files.

Filters: Used to select specific records from a dataset.

Sampling: Selecting a subset of data for examination instead of testing the entire population.

Joins: Combining records from multiple tables or files using related fields.

11. Common CAAT Tests

Completeness Testing: Checks whether all records exist (e.g., ensure all payroll employees are included).

Accuracy Testing: Checks whether calculations are correct (e.g., verify payroll deductions).

Duplicate Testing: Detects repeated records (e.g., duplicate supplier payments).

Exception Reporting: Identifies unusual transactions (e.g., salaries above approved limits).

Ageing Analysis: Groups outstanding items by time periods (e.g., outstanding debts older than 90 days).

12. Scenario-Based Questions

Scenario 1 – Payroll System with Ghost Workers. Appropriate CAATs: Duplicate testing; Tracing; Parallel simulation.

Scenario 2 – Billing System with Incorrect Pricing. Appropriate CAATs: Test data; Parallel simulation; Exception reporting.

Scenario 3 – Unauthorized Program Changes. Appropriate CAATs: Code comparison; Tracing.

13. Key Exam Summary

Audit Objective	Suitable CAAT
Detect duplicate payments	Duplicate testing
Verify payroll calculations	Parallel simulation
Test invalid data inputs	Test data
Continuous testing	Integrated Test Facility (ITF)
Detect unauthorized changes	Code comparison
Understand transaction flow	Tracing
Analyze large datasets	Audit software (ACL, IDEA, SQL)

14. Conclusion

CAATs are essential tools in modern IS auditing because organizations depend heavily on computerized systems. Through techniques such as test data, ITF, parallel simulation, tracing, mapping, code comparison, and data analytics, auditors can detect fraud, verify controls, analyze large datasets, improve audit quality, and strengthen organizational governance and security. Modern IS auditing relies heavily on technology to audit technology effectively.

CHAPTER EIGHT

CAATs – Part II: Hands-On Lab Session and Assignment 2

Payroll and Creditors Data Analysis

Lab Session – Payroll/Creditors Data Analysis

This hands-on lab guides students through importing, cleaning, and analysing a sample payroll or creditors file using spreadsheet techniques. Each step must be documented as part of the working papers.

Step 1 – Import and Clean the Data

Before any analytical procedure can begin, the auditor must establish the integrity of the data file. Proper data cleaning ensures that test results are meaningful and defensible.

Documentation Requirements

Record the following details in your working papers before proceeding:

File name: Record the exact filename, including extension (e.g., Payroll_Q4_2024.csv)

Source: Identify the system or person who provided the file (e.g., exported from the client's HR payroll module by the IT Manager)

Extraction date: The date on which the data was extracted from the source system

Period covered: The payroll periods represented in the file (e.g., 1 January 2024 to 31 December 2024)

Cleaning Procedures

- Check columns: Confirm all expected fields are present — EmployeeID, EmployeeName, Department, PayDate, GrossPay, Deductions, NetPay, PaymentMethod
 - Verify data types: Ensure numeric fields are stored as numbers, not text. Convert date fields to a recognised date format
 - Remove blank rows: Use AutoFilter or Go To Special > Blanks to locate and remove entirely empty rows
-

- Remove totals rows: Subtotal and grand total rows embedded in the data will distort calculations. Identify and remove them before running tests
- Format numeric columns: Apply a consistent number format (e.g., two decimal places) to all monetary fields. Remove any currency symbols stored as text
- Format date columns: Use a consistent date format (DD/MM/YYYY or YYYY-MM-DD). Standardise any inconsistencies before filtering or sorting by date

Auditor's Note

All changes made to the data file during cleaning must be documented. Never overwrite the original file — work on a copy and retain the original as evidence.

Step 2 – Analytical Tests

Three core tests are performed on the cleaned dataset. Each test targets a specific audit risk area.

Test A – Duplicates Test

Objective: Identify possible duplicate payroll records — instances where the same employee appears to have been paid twice for the same period.

Risk: Duplicate payments represent a potential misappropriation of assets or a payroll processing control failure. Ghost employees may also generate duplicate-like patterns.

Method:

- Concatenate key fields: Create a helper column combining EmployeeID and PayDate using a formula such as =A2&"|"&TEXT(B2,"YYYY-MM-DD"). This creates a unique key that can be tested for repetition.
 - COUNTIF flag: Apply =COUNTIF(\$C\$2:\$C\$1000,C2) to count how many times each key appears. Records with a count greater than 1 are potential duplicates.
 - Conditional formatting: Highlight cells in the helper column where the COUNTIF result exceeds 1.
-

- PivotTable alternative: Drag EmployeeID and PayDate to the Rows area and NetPay to the Values area. Sort by EmployeeID to spot repeated combinations.

Discussion Point

Are duplicates necessarily errors? Not always. Legitimate scenarios include amended payroll runs where corrections were processed, supplementary pay runs for bonuses, and corrected bank details triggering a re-issue. Follow-up procedures would include tracing each flagged record to supporting documentation; confirming whether the first payment was cancelled before the second was processed; and discussing with the payroll manager.

Test B – Missing Values Test

Objective: Detect missing data in critical fields that could indicate control weaknesses, input errors, or the presence of ghost employees.

Risk: Missing identifiers (particularly EmployeeID) undermine the ability to match payroll records to a verified employee master list. Records lacking NetPay may represent incomplete or fraudulent transactions.

Method:

- AutoFilter for blanks: Apply AutoFilter and filter each critical column (EmployeeID, Department, NetPay) for (Blanks). Count and note the number of blank records.
- COUNTBLANK formula: Use =COUNTBLANK(A2:A1000) to count blank cells in the EmployeeID column. Apply the same formula to Department and NetPay columns.
- Conditional formatting: Select the EmployeeID column and apply a rule to highlight blank cells. Extend the same formatting to other critical fields.

Risk Linkage: Ghost employee records often lack complete HR-sourced data such as a valid EmployeeID, Department code, or tax reference. Missing Department codes may indicate records added directly to the payroll module, bypassing HR system integration and access controls.

Test C – Outlier Test

Objective: Identify unusual or extreme payroll values that fall outside expected norms, which may indicate errors, unauthorised payments, or fraudulent manipulation.

Statistical Measures: AVERAGE(NetPay) — the arithmetic mean, sensitive to extreme values. MEDIAN(NetPay) — the midpoint value, more robust to outliers; a large gap between mean and median signals skewness. STDEV(NetPay) — standard deviation measuring the spread of values around the mean.

Z-Score Method: Calculate $Z = (\text{NetPay} - \text{AVERAGE}) / \text{STDEV}$ for each NetPay value. A Z-score above +3 or below -3 indicates a statistically significant outlier.

Department-Level Analysis: Calculate average and standard deviation by department using AVERAGEIF and a PivotTable. An employee in the Warehouse department earning a figure comparable to a senior manager is clearly anomalous when assessed relative to departmental norms.

Discussion Point

Distinguishing reasonable outliers from problematic ones requires context. Reasonable outliers include senior management salaries legitimately above average, and one-off bonuses approved through a formal authorisation process. Potentially problematic outliers include a clerical-grade employee receiving an executive-level payment, or duplicate bonus payments not supported by an authorisation form. All outliers should be traced to supporting documentation.

Assignment 2 – Audit of Trade Creditors

Scenario: You are engaged to perform data analytics as part of the audit of trade creditors for a mid-sized company. Three files have been provided: a vendor master file, an invoices file, and a payments file.

Test 1 – Duplicate Invoices

Objective: Identify invoices that have been recorded or paid more than once for the same vendor.

1. Concatenate InvoiceNo and VendorID into a composite key column.
-

2. Apply COUNTIF to the composite key column to count occurrences of each key value.
3. Flag all records where COUNTIF > 1 as potential duplicate invoices.
4. Extract flagged records to a separate 'Duplicates' worksheet.
5. Sum the InvoiceAmount for all duplicate records to quantify the total exposure.
6. Document: number of duplicate invoice instances, unique InvoiceNo values affected, total duplicated amount, and VendorIDs most frequently appearing in duplicate records.

Test 2 – Completeness / Sequence Test

Objective: Verify that the sequence of cheque numbers or payment transaction IDs is complete and unbroken. Gaps may indicate missing, suppressed, or fraudulent transactions.

7. Sort the payments file by ChequeNo or TransactionID in ascending order.
8. In a helper column, calculate the expected next number: =A2+1.
9. In a further column, compare the actual next record's ID to the expected value:
=IF(A3<>A2+1,"GAP","OK").
10. Filter the helper column for 'GAP' to extract all sequence breaks.
11. For each gap, calculate the number of missing numbers: =A3-A2-1.
12. Document all gaps, their position in the sequence, and the count of missing transaction references.

Note: Not all gaps indicate fraud. Voided cheques, cancelled transactions, or system-generated reversals may legitimately consume a sequence number. Each gap must be investigated with reference to the void register and the payments journal.

Test 3 – Exception Report

Inactive Vendors Receiving Payments: Use VLOOKUP or MATCH in the payments file to check whether any payments have been made to vendors on the inactive list. Flag matches as exceptions, documenting VendorID, VendorName, PaymentDate, and PaymentAmount.

Payments Above Threshold: Determine the authorisation threshold from the client's delegation of authority policy. Filter the payments file for PaymentAmount > threshold. Confirm whether each high-value payment is supported by the required level of authorisation.

Weekend and Holiday Payments: Use the WEEKDAY function

(=WEEKDAY(PaymentDate,2)) to identify payments processed on Saturday (6) or Sunday (7).

Cross-reference payment dates against a list of public holidays.

Test 4 – Ageing Analysis of Outstanding Balances

Objective: Age all outstanding creditor balances at the year-end date and identify balances that have remained unpaid for an unusually long time.

13. Establish the year-end date.
14. Calculate the age of each outstanding invoice: =YearEndDate - InvoiceDate.
15. Using IF or IFS, assign each invoice to an ageing bucket: 0–30 days; 31–60 days; 61–90 days; 91–180 days; Over 180 days.
16. Create a PivotTable summarising total outstanding balances by VendorID and ageing bucket.
17. Sort by the 'Over 180 days' column descending to identify the largest long-outstanding balances.
18. Flag all balances over 180 days for follow-up and management discussion.

Deliverables

Part A – Spreadsheet Workbook

Sheet Name	Test	Contents
Data_Import	Step 1	Cleaned and documented raw data
Duplicate_Invoices	Test 1	Flagged duplicates + total duplicated amount
Sequence_Test	Test 2	Gaps in cheque/transaction sequence
Exception_Report	Test 3	Inactive vendors, over-threshold, weekend payments
Ageing_Analysis	Test 4	Vendor balances aged by bucket at year-end

Part B – Audit Memo (1–2 Pages)

Data Obtained: Describe the three files received, their format, source, extraction date, and period covered. Note any data quality issues encountered during import.

Tools Used: Specify tools and techniques applied — e.g., Excel functions (COUNTIF, VLOOKUP, WEEKDAY, DATEDIF), PivotTables, conditional formatting, manual sequence testing.

Procedures Performed: Provide a brief narrative of each test: what was done, how the data was analysed, and the criteria used to define exceptions.

Key Findings: Summarise results: number of duplicate invoices found, total duplicated amount, sequence gaps identified, exceptions flagged, and significant long-outstanding balances.

Preliminary Conclusions: Assess whether the findings indicate material control weaknesses or potential misstatements in the trade creditors balance.

Further Audit Steps: Recommend follow-up procedures: obtain management explanations for exceptions, trace duplicates to payment records, confirm inactive vendor status with the procurement department.

Control Recommendations: Suggest improvements: automated duplicate invoice detection at point of entry, periodic purging of inactive vendor records, system-enforced blocking of weekend payment runs, regular creditor reconciliations.

CHAPTER NINE

Auditing Automated Systems

The NetFlow ISP Case Study

1. Overview and Learning Objectives

This case study places students in the role of an IT auditor reviewing the automated billing environment of NetFlow ISP, a mid-sized internet service provider. Working through the case, students will: map an order-to-cash (O2C) process across multiple integrated systems; identify control weaknesses in an automated billing environment; link each weakness to a financial statement assertion; propose practical control improvements; and draft an audit finding in the standard Condition / Criteria / Cause / Effect / Recommendation structure.

2. Case Scenario: NetFlow ISP

2.1 Business Background

NetFlow ISP is a mid-sized internet service provider serving approximately 50,000 residential and small-business subscribers. The company bills customers on a hybrid model: a fixed monthly subscription fee plus usage-based overage charges when customers exceed their data or voice allowance. Revenue is material and largely automated, with minimal manual intervention intended in the normal billing cycle. The finance team is under pressure to close accounts quickly at each month-end, and the business has grown rapidly through acquisition, resulting in a patchwork of legacy configurations in the billing engine and CRM.

2.2 Systems and Data Flows

Four systems form the end-to-end billing chain:

System	Role	Key Inputs/Outputs	Noted Risk
CRM	Customer sign-up, plan selection, credit limits	Customer master record, plan code, credit limit	Sales staff create and modify without review

System	Role	Key Inputs/Outputs	Noted Risk
Network system	Logs data and voice usage per customer account	Nightly batch of usage records to billing engine	Failed batches are not monitored
Billing engine	Applies price plans to usage; generates invoices	Invoice file to ERP AR module	Price plan changes require no approval
ERP (GL/AR)	Posts invoices; tracks collections; processes write-offs	AR ageing, cash receipts, journal entries	Back-dating and single-approver write-offs

3. Order-to-Cash Process Map

Stage	System	Key Data Flow	Risk Flag	Control Note
1. Order	CRM	Customer master, plan code, credit limit	Sales set own credit limits	No independent review of customer data
2. Activation	CRM/Network	Service provisioned; account live	Credit override not logged	Overrides bypass credit policy
3. Usage capture	Network → Billing engine	Usage records via nightly batch	Failed batches unmonitored	No alert or reconciliation control
4. Billing	Billing engine	Price plan x usage = invoice	Price plans changed without approval	No change management workflow

Stage	System	Key Data Flow	Risk Flag	Control Note
5. Period-end	Billing engine → ERP	Invoice posted to AR ledger	Back-dated postings permitted	Closed periods not locked
6. AR & write-off	ERP	Ageing; write- off journal	Single- approver write- offs	Structuring risk below threshold
7. Collection	ERP/Bank	Cash receipt matching	Generally adequate	—

4. Key Control Weaknesses

Weakness 1: Sales Staff Create Customer Master Data Without Independent Review [High Risk]

Why it matters: Sales staff can create fictitious customers, inflate credit limits, or assign incorrect price plans. This threatens the existence and accuracy assertions over AR balances.

Recommended control improvement: Implement dual-authorisation for all new customer creations and credit limit changes. Role-based access controls should separate data entry (sales) from approval (credit or finance team). All master data changes must be logged.

CAAT audit test: Extract the complete customer master change log from the CRM. Identify: (a) all new accounts created by sales staff user IDs; (b) accounts where the creating user also set or modified the credit limit in the same session; and (c) accounts whose credit limit exceeds a management-approved threshold.

Weakness 2: Failed Nightly Usage-to-Billing Batches Are Not Monitored [High Risk]

Why it matters: When the nightly batch fails, customers are under-billed or not billed at all for actual consumption. This is a direct threat to the completeness of revenue recognised in each period.

Recommended control improvement: Implement automated job scheduling alerts for any failed or incomplete batch. Introduce a daily reconciliation dashboard comparing total usage volume recorded in the network system against usage received by the billing engine.

CAAT audit test: Obtain the batch job execution log and the billing engine's usage-receipt log. Reconcile daily usage totals between the two sources. Identify periods where the variance exceeds a defined materiality threshold. Also identify all customers with active services who show zero billed usage in any calendar month.

Weakness 3: Price Plan Changes Without Formal Approval or Pre-Deployment Testing [High Risk]

Why it matters: An unauthorised or erroneous price change affects every invoice generated on that plan. Even a small rate reduction applied to thousands of subscribers causes material revenue loss. This threatens both the accuracy of revenue and the cut-off of any correction.

Recommended control improvement: Introduce a formal change management workflow: pricing change request submitted in writing, reviewed by finance, approved by a commercial authority, tested in a non-production environment, and documented at go-live.

CAAT audit test: Extract the complete price plan change log. Analyse: (a) distribution by user — are changes concentrated among individuals who lack commercial pricing authority? (b) timing — are changes clustered at month-end or year-end? (c) magnitude — flag rate reductions greater than a defined percentage for management justification.

Weakness 4: Finance Staff Can Rerun Billing Batches and Post Back-Dated Invoices Without Restriction [High Risk]

Why it matters: The ability to post back-dated invoices into closed or prior periods breaks the integrity of the accounting record. Revenue can be inflated in the current period or shifted across periods to meet targets. Both practices directly threaten the cut-off and accuracy assertions.

Recommended control improvement: Lock closed accounting periods in the ERP; any prior-period posting must require a period-reopening request approved by the CFO. Billing engine reruns must require dual approval before execution.

CAAT audit test: Extract the full AR invoice posting log. Compare each invoice's document date against its system posting date. Flag all invoices where the document date precedes the posting date by more than a defined threshold (e.g., 30 days). Quantify the revenue impact of all back-dated entries by period.

Weakness 5: Write-Offs Below the Threshold Require Only One Manager's Approval
[Medium Risk]

Why it matters: A single approver can authorise write-offs for connected parties or fictitious balances without any independent check. The structuring risk is significant: a large balance can be written off in multiple sub-threshold tranches, each approved individually. This threatens the existence and valuation assertions over AR.

Recommended control improvement: Require dual-approval for all write-offs above a de minimis amount. Implement a system control that aggregates multiple write-offs to the same customer within a rolling 90-day window and triggers escalation if the cumulative amount exceeds the threshold.

CAAT audit test: Extract all write-off entries from the ERP. Run a structuring analysis by grouping write-offs by customer and by approver; identify customers where the total written off in any rolling 90-day period exceeds the single-transaction threshold. Cross-reference approver user IDs against the AR and sales team roster to identify conflicts of interest.

5. Student Tasks

Task 1 – Map the O2C process (15 minutes): Draw the full order-to-cash cycle for NetFlow ISP, showing all six stages, identifying which system handles each stage, annotating data flows between systems, and noting where a control failure at one stage could affect financial reporting at a later stage.

Task 2 – Identify at least five control weaknesses (20 minutes): For each weakness identified, document the O2C stage at which it occurs, the specific control that is absent or deficient, the financial statement assertion most at risk, and whether the weakness relates to an IT application control, IT general control, or manual control.

Task 3 – Propose control improvements and audit tests (25 minutes): For each weakness, prepare a practical control improvement specifying whether it is preventive or detective; and at least one CAAT-based audit test specifying the data source, extraction criteria, analysis technique, and exception output.

Task 4 – Draft an audit finding memo (20 minutes): Choose the most financially significant weakness and draft a one-page audit finding memo using the five-element structure: Condition, Criteria, Cause, Effect, and Recommendation.

6. Assessment and Marking Guidance

Task	Assessment Criteria	Marks	Indicators of Excellence
Task 1	Correct identification of all six stages; systems correctly matched; data flows annotated; handoff types distinguished	20	Identifies cascading risk between stages; uses a formal notation (e.g., swimlane)
Task 2	At least five weaknesses identified; assertion correctly stated for each; control type correctly classified	25	Identifies structuring risk and interface risk not explicitly stated in the scenario
Task 3	Practical improvement proposed for each weakness; CAAT fully specified with data source, criteria, analysis, and exception output	35	CAATs are quantified (e.g., include a formula for estimating financial exposure)
Task 4	All five memo elements present; condition factual; effect quantified;	20	Uses scenario data to estimate an exposure amount; identifies the responsible owner for remediation

Task	Assessment Criteria	Marks	Indicators of Excellence
	recommendation specific and actionable		

7. Discussion Questions and Further Reading

- How does the hybrid billing model (fixed subscription plus usage-based overage) create different control risks compared with a purely fixed-fee model?
- What IT general controls would you expect to test before relying on the automated application controls in the billing engine?
- The billing engine can rerun batches and post back-dated invoices. Under ISA 240, what does this capability tell you about the risk of management override of controls?
- If the external auditor relies on the internal audit team's CAAT results, what additional procedures are required under ISA 610?

Key Standards and References

- ISA 315 (Revised 2019) — Identifying and Assessing the Risks of Material Misstatement
 - ISA 330 — The Auditor's Responses to Assessed Risks
 - ISA 240 — The Auditor's Responsibilities Relating to Fraud in an Audit of Financial Statements
 - ISACA — COBIT 2019 Framework: Governance and Management Objectives
 - AICPA — Guide to Audit Data Analytics (2018), Chapter 4
-

CHAPTER TEN

CAATs Lab: Creditors and Payroll Dataset Analysis

Practical Data Analysis and Findings

Part A: Creditors (Accounts Payable) Dataset

The dataset used contains three linked files: a Vendor Master file, an Invoices file, and a Payments file. All work was performed in Microsoft Excel.

Task 1: Identifying Duplicate Invoices and Payments

A helper column was created by concatenating three key fields — VendorID, InvoiceNo, and Amount — using: =A2&"-"&B2&"-"&C2. This created a unique composite key for each invoice. COUNTIF was then applied to count how many times each combination appeared: =COUNTIF(\$D\$2:\$D\$500,D2). Any row where the count came back greater than 1 was flagged as a potential duplicate, highlighted with conditional formatting (red fill). The Payments file was cross-referenced similarly using VendorID, PaymentAmount, and PaymentDate.

Key Findings:

- 3 exact duplicates — same VendorID, same InvoiceNo, same amount, posted on different dates (suggesting the invoice was entered twice by two different staff members or submitted twice by the vendor)
- 4 near-duplicates — same VendorID and same amount, but with slightly different invoice numbers (e.g., INV-2024-0045 and INV2024-45), suggesting deliberate alteration of the invoice number to bypass an automated duplicate check
- 2 vendors received double payments within a 3-day window for the same amounts: one for KSh 245,000 and another for KSh 87,500
- Total value of suspected duplicate payments: KSh 332,500

The near-duplicates are particularly concerning as they suggest either that the system's duplicate detection is not robust enough (it only catches exact matches on invoice number) or someone is deliberately manipulating invoice numbers to extract double payments.

Task 2: Flagging Payments to Inactive Vendors and Those with Missing Approval

References

VLOOKUP was used to bring the vendor Status field from the Vendor Master file into the Payments file, matching on VendorID: =VLOOKUP(A2, VendorMaster!\$A:\$E,4,FALSE). The Payments file was then filtered to show only rows where the returned status was 'Inactive' or 'On Hold'.

Key Findings:

- 4 payments were made to vendors with 'Inactive' status in the vendor master. Two of these vendors had been deactivated over 6 months ago. Combined value: KSh 156,000
- 11 invoices were processed and paid without a corresponding Purchase Order number — no PO reference linking the payment back to an approved procurement. Combined value: KSh 412,800
- One of the payments to an inactive vendor also had no PO reference — making it doubly suspicious

Payments to inactive vendors suggest that either the system does not have a hard block preventing transactions against inactive accounts, or someone with sufficient system access manually overrode the status. This could indicate a fictitious vendor scheme — deactivating a vendor on paper while continuing to process payments.

Part B: Payroll Dataset

CAAT tests applied to the payroll dataset:

- Duplicate bank account detection across all employee records
- Duplicate National ID detection
- Outlier analysis using Z-scores by grade and department
- Completeness check for critical master data fields (Department, Grade, BankAccount, ApprovalRef)

Key Findings:

- 3 shared bank accounts across 7 employees; 1 blank-name suspect record (EMP-198) receiving salary into a shared account
-

- 1 duplicate National ID identified
- 6 employees with statistically anomalous net pay (Z-score > 2)
- 8 records missing Department, 2 missing bank account, 14 missing approval references

Preliminary Conclusions: The payroll master file has serious integrity issues. The presence of a blank-name employee (EMP-198) receiving salary into a shared bank account with no approval reference and no department is a strong indicator of ghost worker fraud. The outlier analysis reveals that at least some employees are receiving significantly more than what their grade would justify, suggesting either unauthorized pay rate changes or manipulation of allowances.

Suggested Follow-Up Audit Steps

- Immediately investigate EMP-198 — obtain HR file, employment contract, pay slips; verify physical existence
- For all 3 shared bank accounts, request bank statements and trace to named account holders
- For the 6 outliers, obtain approved pay scales and compare to actual pay; investigate allowance authorizations
- For the 14 records with no approval reference, verify whether approvals exist in paper form or whether these were unauthorized additions
- Recommend a physical headcount exercise verified by departmental managers against the payroll list

Plenary Discussion: CAATs vs. Traditional Sampling

When running the duplicate test on the entire creditors dataset in Excel, we tested all 500 invoices simultaneously. The test took about 3 minutes to set up and returned results instantly. We went from 5% coverage (a sample of 25) to 100% coverage without adding any significant time to the audit.

That is what CAATs fundamentally change about IS auditing. They do not just make auditing faster — they make it more complete. When you test a sample, you can only say 'in my sample of 25, I found no duplicates.' When you test the full population, you can say 'across all 500

invoices for the entire year, I identified 7 duplicates totalling KSh 332,500, and here they are.' That is a fundamentally different and stronger audit conclusion.

CAATs are also especially powerful when cross-referencing files that were never designed to talk to each other. The vendor master and the employee master live in different systems. No one in AP is regularly comparing vendor bank accounts to employee bank accounts. But a VLOOKUP join in Excel can perform this cross-system analysis in about 10 minutes — something that simply cannot be done efficiently without data-driven tools.

The key lesson: CAATs do not replace professional judgment. The tool flags EMP-198 as suspicious. The auditor still has to verify — obtain the HR file, talk to the department head, trace the bank account. CAATs narrow the field dramatically and point you to where the problems are. What happens after that still requires an experienced human who understands the business, asks the right questions, and knows a genuine finding from a coincidence.

Anomaly-to-Control Mapping

Anomaly Found	Control That Should Have Prevented It
7 duplicate invoices in creditors	Automated duplicate detection in AP system (same VendorID + InvoiceNo + Amount = block)
Payments to inactive vendors	System hard-block: status = 'Inactive' → payment transaction rejected
11 invoices with no PO	Enforce mandatory PO reference field; system should not allow payment posting without PO linkage
Ghost worker (EMP-198) in payroll	Segregation of duties: HR creates employees, Payroll processes them, Finance approves payment
Shared bank accounts	Duplicate bank account detection on employee master; dual control for bank detail changes
14 payroll records with no approval	Workflow-based approval: employee record not active in payroll until HR manager's digital sign-off is recorded

Anomaly Found	Control That Should Have Prevented It
Outlier net pay	Automated alert when employee's pay exceeds grade maximum; exception report for all pay above ± 2 standard deviations

CHAPTER ELEVEN

Auditing Non-Monetary Information Systems

University Student Information System (SIS) Audit

1.0 Introduction

Information Systems (IS) auditing involves evaluating whether information systems adequately protect data, maintain integrity, ensure confidentiality, and support reliable operations within an organisation. Non-monetary systems are particularly important because although they may not directly process financial transactions, they support critical operational activities whose failure may result in operational disruptions, reputational damage, legal consequences, and poor decision-making.

This assignment focuses on auditing a University Student Information System (SIS) used to manage student admissions, registration, course enrolment, examination records, GPA calculations, transcript generation, and graduation processing.

Audit Aims

The audit aims to evaluate whether the SIS maintains: information integrity; completeness of records; timeliness of updates; confidentiality of student data; and adequate IT security controls.

2.0 Background of the Student Information System

The main users of the system include: students; lecturers; examination officers; academic registrars; faculty administrators; IT administrators; and university management.

Although the SIS is classified as a non-monetary information system, errors or manipulation within the system may significantly affect students' academic progress, scholarships, graduation eligibility, and the institution's reputation.

3.0 Audit Objectives

3.1 Maintains Information Integrity: Ensures student records, marks, grades, and transcripts are accurate, valid, and reliable.

3.2 Ensures Completeness: Captures all student enrolments, examination records, and academic activities completely.

3.3 Promotes Timeliness: Ensures marks, enrolments, and academic records are updated within required timelines.

3.4 Protects Confidentiality: Restricts access to sensitive student information and examination records to authorised personnel only.

3.5 Provides Adequate Security and Availability: Protects the system from unauthorised access, cyber threats, data loss, and operational disruptions.

4.0 Key Risks Identified

Risk 1 – Incorrect Student Biodata: Inaccurate student information such as names, identification numbers, contacts, or programme details may lead to incorrect academic records and transcript errors.

Risk 2 – Unauthorised Modification of Examination Marks: Examination marks may be altered without proper approval, resulting in academic fraud, unfair grading, and loss of confidence in the university's examination processes.

Risk 3 – Missing Student Enrolments: Some students may attend classes or sit examinations without being properly enrolled, affecting examination eligibility, class lists, and academic reporting.

Risk 4 – Failure to Capture Student Marks: Marks for some students may not be entered due to human error or system failure, leading to incorrect GPA calculations and delays in academic progression or graduation.

Risk 5 – Delayed Entry of Examination Marks: Examination results may be entered later than required timelines, affecting transcript preparation, graduation processing, and release of academic results.

Risk 6 – Unauthorised Access to Student Records: Sensitive student information such as grades, disciplinary records, and personal details may be accessed by unauthorised individuals, resulting in privacy breaches.

Risk 7 – Weak Passwords and Shared User Accounts: Users may use weak passwords or share login credentials, increasing the risk of unauthorised system access and compromising accountability.

Risk 8 – System Downtime During Critical Periods: The SIS may become unavailable during registration or examination periods due to technical failures or inadequate system capacity, disrupting university operations.

Risk 9 – Lack of Audit Trails: If the system does not maintain proper logs of changes made to records, it becomes difficult to detect fraud, investigate incidents, or identify users responsible for unauthorised activities.

Risk 10 – Exposure of Confidential Student Information: Confidential student information may be exposed through poor security practices or weak access controls, resulting in violations of data protection laws and university policies.

5.0 Expected Controls

Control 1 – Input Validation Controls: The system should include validation controls such as mandatory fields, format checks, and verification procedures to ensure accurate student information is entered.

Control 2 – Role-Based Access Controls: Access to the system should be restricted according to users' job responsibilities. Lecturers should only access marks for the units they teach; students should only view their own records.

Control 3 – Approval Workflows for Mark Changes: Changes to examination marks should require approval from authorised personnel such as examination officers or academic registrars to prevent unauthorised modifications.

Control 4 – Audit Trails and Logging: The system should maintain logs showing who accessed or changed records, when the changes were made, and what information was modified.

Control 5 – Automated Enrolment Verification: Controls should exist to confirm that all students registered for courses are properly enrolled in the system and eligible to sit examinations.

Control 6 – Exception Reporting: The system should generate reports identifying students with missing marks, incomplete registrations, or inconsistent records to support timely correction of errors.

Control 7 – Strong Password Policies and Multi-Factor Authentication: Users should be required to use strong passwords, and multi-factor authentication should be implemented to strengthen system security.

Control 8 – Individual User Accounts: Each system user should have a unique account to improve accountability and prevent misuse associated with shared accounts.

Control 9 – Backup and Disaster Recovery Controls: Regular system backups and disaster recovery plans should be implemented to ensure continuity of operations and recovery of data in case of system failure.

Control 10 – Network and Security Controls: Firewalls, encryption, VPN access, and continuous monitoring should be implemented to protect the system against cyber threats, unauthorised access, and data breaches.

6.0 Audit Procedures

6.1 Process-Level Audit Procedures

Procedure 1 – Review Policies and Procedures (Test of Control): Obtain and review university policies governing student registration, marks entry and approval, examination moderation, graduation approval, and data privacy. Purpose: To determine whether formal governance and control procedures exist.

Procedure 2 – Conduct a System Walk-through (Test of Control): Select one student and trace the process from admission through registration, course enrolment, marks recording, GPA calculation, and graduation. Purpose: To understand the operation of the system and identify weaknesses in controls.

Procedure 3 – Interview Key Personnel (Test of Control): Interview lecturers, examination officers, registry staff, and IT administrators on access rights, approval procedures, handling of mark changes, and security practices. Purpose: To confirm whether controls operate as documented.

6.2 Logical Access Control Procedures

Procedure 4 – Review User Access Rights (Test of Control): Obtain a list of all user accounts and roles; sample users from different departments; verify whether access rights match job responsibilities. Purpose: To assess compliance with the principle of least privilege.

Procedure 5 – Review Privileged and Shared Accounts (Test of Control): Identify administrator accounts; determine whether generic/shared accounts exist; review password policies; assess implementation of multi-factor authentication. Purpose: To evaluate authentication and authorisation controls.

Procedure 6 – Review System Logs and Audit Trails (Substantive/Data Analysis): Examine failed login attempts, mark changes, user account modifications, and access to confidential records. Purpose: To identify possible unauthorised access or suspicious activities.

6.3 Data Integrity and Completeness Procedures

Procedure 7 – Identify Students with Marks but No Enrolment (Data Analysis): Compare examination records with enrolment records to identify inconsistencies. Purpose: To detect invalid or unauthorised academic records.

Procedure 8 – Identify Students Enrolled but Missing Marks (Data Analysis): Identify students registered in units but without recorded marks. Purpose: To assess completeness of examination records.

Procedure 9 – Recalculate GPA and Academic Status (Data Analysis): Independently recalculate GPA for sampled students and compare results with system-generated calculations. Purpose: To verify the accuracy and reliability of GPA calculations.

Procedure 10 – Review Audit Trail for Mark Changes (Data Analysis): Review all mark amendments after initial entry and verify who made the change, date and time, approval evidence, and reason for the amendment. Purpose: To detect unauthorised modification of examination records.

6.4 IT General Controls Procedures

Procedure 11 – Review Backup and Disaster Recovery Procedures (Test of Control): Verify frequency of backups, storage of backups offsite, existence of disaster recovery plans, and testing of recovery procedures. Purpose: To ensure data can be recovered in case of system failure.

Procedure 12 – Review Physical Security Controls (Test of Control): Inspect server rooms, records offices, CCTV systems, access controls, and visitor logs. Purpose: To evaluate protection of physical infrastructure and records.

Procedure 13 – Review Network and Application Security (Test of Control): Verify existence of firewalls, use of HTTPS/TLS encryption, VPN implementation for remote access, and vulnerability assessments and remediation. Purpose: To determine whether the system is protected against cyber threats.

7.0 Potential Findings and Recommendations

Finding 1 – Weak Controls Over Mark Changes: Lecturers can modify marks without secondary approval, creating a risk of unauthorised alteration of examination results. Recommendation: Implement approval workflows requiring examination office authorisation for all mark changes.

Finding 2 – Excessive User Access Rights: Some staff members have access beyond their job responsibilities, creating a risk of unauthorised access to confidential student records. Recommendation: Conduct regular user access reviews and enforce role-based access controls.

Finding 3 – Delayed Entry of Examination Marks: Marks are entered several weeks after examinations, creating risks of delayed transcript processing and graduation decisions. Recommendation: Establish timelines and monitor compliance with marks submission deadlines.

Finding 4 – Inadequate Monitoring of System Logs: System logs are not regularly reviewed, meaning fraudulent or suspicious activities may go undetected. Recommendation: Implement continuous monitoring and periodic review of audit logs.

8.0 Conclusion

The Student Information System is a critical non-monetary information system that supports core academic and administrative operations within the university. Effective controls are necessary to ensure the integrity, completeness, timeliness, confidentiality, and security of student

information. The audit procedures outlined in this report provide a structured approach for evaluating whether the SIS adequately protects student records, prevents unauthorised access, supports reliable academic processing, and complies with institutional policies and data protection requirements.

CHAPTER TWELVE

IS Audit of a Payroll Information System

Full Audit Case Study

Part 1: System and Context

What system: A payroll information system used by a mid-sized organization to process monthly salaries, allowances, deductions, and statutory remittances (PAYE, NSSF, NHIF).

What processes it supports: The system receives employee master data from the HR module (grades, basic pay, bank details, tax codes). Each month, payroll processing staff run the payroll cycle — the system calculates gross pay, applies allowances and deductions, computes net pay, generates payslips, produces a payment file sent to the bank, and posts payroll totals to the general ledger.

Key stakeholders: HR department (maintains employee records); Payroll department (runs the monthly cycle); Finance/Treasury (releases bank payments); Internal Audit (oversight); Tax Authority (PAYE compliance); Employees (recipients of payment).

Why this system is high risk: Payroll is typically one of the largest expenditure items on the income statement. Errors or fraud here are financially material. Ghost workers, inflated allowances, and unauthorized pay changes are common fraud schemes. The system also handles highly sensitive personal data (salaries, bank accounts, tax information) which creates a confidentiality obligation.

Part 2: Key Risks

Risk 1 – Ghost Workers (Integrity/Completeness): Individuals who do not work for the organization are included on the payroll and receive salaries. This can happen when terminated employees are not removed promptly, or when payroll staff create fictitious employee records. The financial impact can be significant and may go undetected for long periods if access controls and reconciliation controls are weak.

Risk 2 – Unauthorized Changes to Master Data (Integrity): Pay rates, grades, bank account numbers, or tax codes could be changed without proper authorization. A payroll officer with

broad system access could increase their own salary, redirect another employee's salary to a different bank account, or change tax codes to reduce deductions.

Risk 3 – Incorrect Payroll Calculations (Accuracy): The system may apply wrong tax rates, outdated NSSF/NHIF contribution tables, or incorrect overtime calculation rules — especially after legislative changes if the system is not updated promptly. This affects both the accuracy of individual employee payments and the organization's statutory compliance.

Risk 4 – Weak Segregation of Duties (Integrity/Availability): If the same person or role can create employees, input changes, run payroll, and authorize the bank payment file, there is no independent check at any stage. This is the condition that makes most payroll fraud possible.

Risk 5 – Unauthorized Access to Payroll Data (Confidentiality): If access controls are weak, employees could view colleagues' salaries, HR staff could browse executive compensation, or external parties could access the system through compromised credentials, creating legal exposure under data protection laws.

Risk 6 – System Downtime at Critical Processing Points (Availability): If the payroll system is unavailable on the processing or payment date — due to hardware failure, power outage, or ransomware — employees may not be paid on time. Lack of a tested disaster recovery plan makes this risk worse.

Risk 7 – Non-Compliance with Tax and Labor Laws (Compliance): Failure to correctly calculate and remit PAYE, NSSF, and NHIF on time exposes the organization to statutory penalties and interest. If the system's tax tables are not updated after legislative changes, every payroll run will produce incorrect statutory deductions.

Risk 8 – Poor Audit Trail for Payroll Adjustments (Integrity): Manual adjustments, off-cycle payments, and retroactive corrections made outside the standard payroll run are high-risk if not logged and approved. Without a complete audit trail, it becomes impossible to reconstruct what happened when disputes arise or investigations are conducted.

Part 3: Planned Audit Approach

Main Process Steps to Review

19. Employee master data maintenance (creation, changes, terminations)
-

- 20. Monthly payroll calculation run
- 21. Payment file generation and bank submission
- 22. GL posting
- 23. Statutory remittance reporting

Key General IT Controls (GITCs) to Test

Access Management: Obtain the user access listing for the payroll system. Confirm that access is role-based and that no single user has access to both master data maintenance and payment authorization. Check that terminated employees' system accounts were disabled promptly. Review password policies and confirm MFA is in place for remote access.

Change Management: Confirm that updates to tax tables, pay scales, and system configuration go through a formal change request and testing process before being applied to production. Check for any changes made directly to production without going through the change management process.

Backup and Recovery: Review backup logs to confirm daily backups of payroll data run successfully. Confirm that restoration tests have been conducted and documented within the past year. Assess whether the recovery time objective (RTO) for the payroll system is aligned with the monthly processing deadline.

Key Application Controls to Test

Input controls: Verify that the system enforces mandatory fields for all employee records (employee number, national ID, bank account, grade, department). Test whether the system rejects invalid entries such as negative basic pay, duplicate national IDs, or bank accounts in formats that do not match validation rules.

Processing controls: Using parallel simulation, independently recalculate a sample of employees' gross pay, statutory deductions (PAYE using current KRA tax bands, NSSF, NHIF), and net pay. Compare results to what the system produced. Any material differences indicate a calculation error in the system configuration.

Master data controls: Review the workflow for creating new employees and changing bank details. Confirm that these actions require a second authorizer who is independent of the person making the change. Review the audit log of all master data changes in the period.

CAATs to Be Used

Ghost worker detection: Extract the full payroll list and the HR staff list. Join them on employee number and national ID. Flag any employee appearing on the payroll but not on the HR active staff list. Also flag employees sharing the same bank account number or national ID.

Duplicate payment detection: Check for employees paid more than once in the same pay period. Also check for the same bank account number receiving more than one salary payment.

Outlier analysis: Compute average and standard deviation of net pay by grade and department. Flag employees whose net pay deviates significantly from the mean for their grade. Also flag employees with zero deductions (possible tax code manipulation) or deductions significantly lower than expected for their income band.

Joiners and leavers testing: Extract a list of employees whose status changed during the year. For leavers, confirm that the last pay date aligns with the termination date and that no further payments were made after termination. For joiners, confirm that the first pay date and amount align with the offer letter and contract.

Part 4: Sample Findings and Recommendations

Finding 1 – Ghost Workers Identified (High Severity)

Condition: CAAT analysis identified 14 employees on the payroll whose names and national IDs do not appear on the HR active staff list. Total payments to these individuals during the year amounted to Ksh 3.2 million.

Criteria: Only current, verified employees should receive salary payments. HR records and payroll records should be reconciled monthly.

Cause: No formal monthly reconciliation process exists between HR and payroll. The payroll module does not automatically disable payment to employees who are terminated in the HR module.

Consequence: Potential payroll fraud resulting in material financial loss. Regulatory exposure if ghost workers are linked to fictitious NSSF/NHIF contributions.

Recommendation: Implement an automated interface between the HR and payroll modules so that HR terminations immediately flag payroll records for review and removal. Conduct an immediate independent investigation of the 14 flagged employees. Implement a mandatory monthly sign-off by department heads confirming their staff list matches payroll.

Finding 2 – Weak Segregation of Duties (High Severity)

Condition: Three payroll officers have system roles that allow them to both create and modify employee master records and run the monthly payroll cycle. Two of these officers also have access to review the bank payment file before submission.

Criteria: No individual should be able to create or modify employee records and also process or approve payments for those employees (ISACA ITAF, internal control policy).

Cause: Role design was done during system implementation without a formal segregation of duties matrix. No review of role assignments has been conducted since go-live.

Consequence: Any one of these three officers could create a ghost employee and process payment without an independent check, making detection unlikely until an external audit or complaint.

Recommendation: Redesign system roles so that master data maintenance and payroll processing are assigned to separate, incompatible roles. Conduct an immediate role clean-up across all payroll users. Establish a quarterly access review where the HR Manager and Finance Manager jointly sign off on all payroll system access rights.

Finding 3 – Outdated Tax Tables (Medium Severity)

Condition: Parallel simulation using current KRA PAYE tax bands revealed that 23% of employees in the middle income band had PAYE deducted at the previous year's rates. The difference per employee per month averages Ksh 850, representing a total under-deduction of approximately Ksh 480,000 over the year.

Criteria: PAYE calculations must reflect the current Finance Act rates. The system's tax tables should be updated at the start of each financial year.

Cause: No formal change management process exists for updating tax tables. The update was not included in the system administration calendar and was missed when the new rates came into effect.

Consequence: The organisation has under-remitted PAYE to KRA, creating a tax liability plus potential penalties and interest. Employees may face individual tax assessments.

Recommendation: Establish a formal change management procedure for statutory rate updates. Assign responsibility to a designated system administrator with a checklist of annual updates. The Finance Manager should sign off on tax table changes after each Finance Act amendment. Quantify and remit the outstanding PAYE liability as soon as possible.